PUSTAKANUSA

Panduan Penggunaan dan Laporan Audit Aplikasi

Dokumentasi fitur, cara pemakaian, pemeriksaan teknis, dan daftar temuan

Status pemeriksaan

Kode berhasil melewati pemeriksaan sintaks dan dependensi terpasang. Audit statis menemukan 10 isu yang perlu ditindaklanjuti: 2 risiko tinggi, 6 sedang, dan 2 rendah.

Informasi	Nilai
Nama aplikasi	PustakaNusa
Tanggal audit	17 Oktober 2026
Cakupan	Frontend, backend, skema database, alur role, dan dokumentasi
Format	Panduan pengguna + laporan audit teknis
Versi dokumen	1.0

Dokumen ini disusun berdasarkan kondisi source code saat audit. Pembayaran pada versi ini masih berupa simulasi dan belum memverifikasi transaksi melalui payment gateway.

1. Ringkasan eksekutif

PustakaNusa adalah aplikasi perpustakaan berbasis web dengan tiga role: Pengguna, Petugas, dan Superadmin. Alur utamanya mencakup katalog, peminjaman dengan QR, pengembalian, pengaduan beserta foto, denda, notifikasi, dan pengelolaan akun.

Kesimpulan singkat

Aplikasi dapat dilanjutkan untuk pengembangan/demo, tetapi belum layak dianggap aman untuk produksi sebelum isu stok pengembalian dan konfigurasi JWT diperbaiki. Pengujian integrasi juga belum tersedia.

Hasil pemeriksaan

Area	Hasil
Sintaks JavaScript	Lulus — npm run check
Dependensi terpasang	Lulus — npm ls --depth=0 tidak menemukan dependency invalid/missing
Review alur bisnis	Ditemukan isu pada stok, denda, notifikasi, QR, dan penghapusan data
Review hak akses	Role dasar diterapkan, tetapi ada target notifikasi yang tidak sesuai role
Uji database/browser	Belum dijalankan end-to-end karena tidak tersedia database uji terisolasi
Automated tests	Belum tersedia; script check hanya memeriksa sintaks

Prioritas tindakan

1. Batasi endpoint pengembalian hanya untuk status dipinjam atau terlambat agar stok tidak bertambah secara tidak sah.
2. Wajibkan JWT_SECRET yang kuat dan hentikan server bila variabel tersebut tidak tersedia.
3. Selaraskan notifikasi/alert peminjaman dengan status siap_diambil dan batasi notifikasi pendaftaran hanya untuk Superadmin.
4. Perbaiki urutan denda keterlambatan serta relasi penghapusan pengaduan dan pembayaran.
5. Tambahkan pengujian integrasi untuk stok, QR, role, denda, dan penghapusan data.

2. Gambaran aplikasi

Fitur utama

Modul	Kemampuan
Autentikasi	Satu halaman login; role ditentukan otomatis dari akun.
Katalog	Cari buku, filter kategori, lihat detail dan cover.
Peminjaman	Ajukan buku, tampilkan/unduh QR, pindai QR oleh petugas, tetapkan jatuh tempo.
Pengembalian	Validasi pengembalian, tandai keterlambatan, input denda, lihat riwayat.
Pengaduan	Pengguna mengirim aduan dengan maksimal lima gambar; petugas memproses dan menetapkan denda.
Pembayaran denda	Pilihan VA BCA, QRIS, GoPay, DANA, dan OVO; pencatatan metode pembayaran.
Notifikasi	Badge unread, tandai dibaca, dan navigasi ke halaman terkait.
Kelola akun	Superadmin menambah, melihat, mengubah role/data, menghapus, dan mengonfirmasi pendaftaran.

Matriks role

Kemampuan	Pengguna	Petugas	Superadmin
Melihat katalog/detail	Ya	Ya	Ya
Mengajukan pinjaman/pengaduan	Ya	Tidak	Tidak
Mengambil buku melalui QR	Menunjukkan QR	Memindai	Memindai
Mengelola koleksi	Tidak	Ya	Ya
Memproses pengembalian/denda	Tidak	Ya	Ya
Melihat pembayaran denda	Milik sendiri	Semua	Semua
CRUD akun & ubah role	Tidak	Tidak	Ya
Konfirmasi pendaftaran	Tidak	Tidak	Ya

Status penting

Objek	Status	Makna
Peminjaman	siap_diambil	QR tersedia; buku belum diserahkan dan stok belum dikurangi.
Peminjaman	dipinjam	QR sudah dipindai; stok berkurang.
Peminjaman	terlambat	Jatuh tempo lewat; petugas dapat menetapkan denda.
Peminjaman	dikembalikan	Pengembalian selesai; stok ditambah.
Pengaduan	baru / diproses / selesai	Tahap penanganan pengaduan.
Pembayaran	menunggu / dibayar	Status tagihan denda.

3. Memulai penggunaan

Persyaratan

- Node.js 20 atau lebih baru.
- npm.
- MySQL 8 atau lebih baru.
- Browser modern; kamera membutuhkan localhost atau HTTPS dan izin browser.

Instalasi lokal

1. Salin .env.example menjadi .env.

2. Isi koneksi database dan JWT_SECRET yang kuat.

3. Jalankan npm install.

4. Impor database/schema.sql ke MySQL.

5. Jalankan npm run dev.

6. Buka http://localhost:3000.

> **Keamanan konfigurasi**
> Jangan gunakan nilai JWT_SECRET bawaan/contoh untuk produksi dan jangan commit file .env ke Git.

Akun demo dari schema

Role	Email	Kata sandi
Superadmin	admin@pustakanusa.local	password
Petugas	petugas@pustakanusa.local	password
Pengguna	alya.rahma@email.id	password

Ganti seluruh kata sandi demo setelah instalasi.

Masuk dan sesi

1. Buka halaman Masuk.

2. Masukkan email. Akun Petugas/Superadmin juga dapat memakai username.

3. Masukkan kata sandi lalu tekan Masuk.

4. Aplikasi membuka dashboard sesuai role secara otomatis.

5. Jika token kedaluwarsa, aplikasi mengarahkan kembali ke login dan menampilkan pesan sesi berakhir.

4. Panduan Pengguna

Mendaftar akun baru

1. Pada halaman masuk, pilih Daftar.
2. Isi nama, email, telepon, alamat, dan kata sandi minimal enam karakter.
3. Kirim pendaftaran.
4. Tunggu Superadmin mengaktifkan akun; akun berstatus menunggu belum dapat login.

Mencari dan melihat buku

1. Buka Katalog.
2. Gunakan pencarian judul/penulis/ISBN atau pilih kategori.
3. Klik kartu buku untuk melihat cover, judul, penulis, kategori, penerbit, tahun terbit, ISBN, jumlah halaman, stok, dan sinopsis.

Mengajukan peminjaman

1. Pada detail buku yang tersedia, pilih Pinjam.
2. Isi lokasi, tanggal, dan waktu pengambilan.
3. Kirim pengajuan. Sistem membuat status siap diambil dan QR pengambilan.
4. Buka Peminjaman, klik data, lalu pilih Detail untuk melihat atau mengunduh QR.
5. Tunjukkan QR kepada Petugas. Setelah dipindai, Petugas mengisi jatuh tempo dan status menjadi dipinjam.
6. Sebelum QR dipindai, peminjaman dapat dibatalkan dari menu baris data.

Batas peminjaman

Maksimal tiga transaksi aktif per Pengguna. Stok baru berkurang ketika QR berhasil dipindai Petugas.

Mengajukan pengaduan

1. Buka Pengaduan.
2. Pilih buku yang pernah dipinjam dan jenis masalah.
3. Tulis deskripsi yang jelas.
4. Unggah hingga lima gambar JPG/PNG/WebP; maksimum 1,2 MB per gambar dan 5 MB total setelah kompresi.
5. Kirim pengaduan dan pantau statusnya.

Gambar bukti dihapus otomatis tujuh hari setelah denda pengaduan dibayar, selama proses server tetap berjalan.

5. Denda, pembayaran, dan notifikasi

Membayar denda

1. Buka Denda/Pembayaran Denda.
2. Klik Pilih pembayaran pada tagihan.
3. Pilih VA BCA, QRIS, GoPay, DANA, atau OVO.
4. Ikuti instruksi yang ditampilkan.
5. Tekan Cek Pembayaran. Pada versi saat ini tombol langsung mencatat status dibayar; belum ada verifikasi gateway nyata.

Notifikasi

1. Klik ikon lonceng di kanan atas.
2. Badge menunjukkan jumlah notifikasi yang belum dibaca.
3. Klik satu notifikasi untuk menandainya dibaca dan membuka halaman terkait.
4. Gunakan Tandai semua sudah dibaca untuk mengosongkan badge.

Pengingat denda

Sistem memeriksa tagihan belum dibayar setiap enam jam dan membuat pengingat ketika jatuh tempo tinggal tiga hari atau sudah lewat. Proses ini bergantung pada server yang tetap aktif.

> **Catatan pembayaran**
> Seluruh pilihan pembayaran masih berupa simulasi UI. Nomor rekening/dompet dan QRIS yang tampil bukan integrasi transaksi nyata.

Menghubungi melalui WhatsApp

Pada menu Pembayaran Denda, Petugas dapat membuka tautan WhatsApp ke nomor Pengguna untuk mengingatkan tagihan. Aplikasi hanya membuka tautan WhatsApp dan belum memakai WhatsApp Business API.

6. Panduan Petugas

Mengelola koleksi

1. Buka Koleksi untuk melihat daftar buku.
2. Klik Tambah buku dan isi judul, penulis, kategori, cover, penerbit, tahun terbit, ISBN, jumlah halaman, sinopsis, harga, dan stok.
3. Klik baris buku untuk membuka pilihan Detail, Ubah, atau Hapus.
4. Buku yang sudah mempunyai riwayat peminjaman tidak dapat dihapus.

Memproses pengambilan QR

1. Buka Peminjaman/Pengambilan buku.
2. Pastikan transaksi tampil pada Daftar pengambilan buku dengan status QR menunggu dipindai.
3. Tekan Pindai QR, izinkan kamera, lalu arahkan ke QR Pengguna. Alternatifnya, tempel kode QR secara manual.
4. Periksa detail Pengguna dan buku.
5. Isi jatuh tempo pengembalian, lalu selesaikan pengambilan.
6. Tutup modal pemindai setelah selesai; kamera semestinya dihentikan saat modal ditutup.

Memproses pengembalian

1. Buka Pengembalian.
2. Klik transaksi berstatus dipinjam/terlambat.
3. Untuk pinjaman terlambat, input nominal dan jatuh tempo denda terlebih dahulu.
4. Validasi pengembalian agar status selesai dan stok buku kembali.
5. Gunakan Riwayat untuk mengganti tampilan dari data aktif ke data selesai.

Memproses pengaduan

1. Buka Pengaduan dan klik satu baris.
2. Periksa deskripsi serta seluruh gambar bukti.
3. Isi nominal dan jatuh tempo denda bila diperlukan.
4. Simpan; pengaduan masuk riwayat dan tagihan muncul pada Pembayaran Denda Pengguna.
5. Untuk buku hilang, peminjaman ditutup dan stok disesuaikan oleh sistem.

Pembayaran denda

Buka Pembayaran Denda untuk melihat anggota, sumber denda, nominal, jatuh tempo, status, metode, dan waktu pembayaran. Klik data untuk detail atau hapus sesuai kebutuhan operasional.

7. Panduan Superadmin

Superadmin memiliki seluruh kemampuan Petugas ditambah pengelolaan akun dan konfirmasi pendaftaran.

Menambah akun

1. Buka Kelola Akun.
2. Tekan Tambah akun.
3. Pilih role Pengguna atau Petugas.
4. Isi identitas dan kata sandi. Untuk Pengguna, lengkapi telepon dan alamat.
5. Simpan akun.

Melihat, mengubah, dan menghapus akun

1. Klik baris akun untuk membuka pilihan Detail akun, Ubah akun, dan Hapus akun.
2. Pada Ubah akun, sesuaikan nama, email, telepon, alamat, status, atau role yang diizinkan.
3. Simpan perubahan.
4. Hapus hanya bila akun tidak memiliki riwayat transaksi; sistem akan menolak penghapusan yang merusak referensi data.

Konfirmasi pendaftaran

1. Buka Kelola Akun dan pilih akun berstatus Menunggu.
2. Buka Ubah akun/detail tindakan.
3. Ubah status menjadi Aktif/Disetujui atau Ditolak.
4. Pengguna yang aktif dapat login.

Aturan perubahan role

- Petugas dapat dinaikkan menjadi Superadmin atau diturunkan sesuai pembatasan sistem.
- Pengguna hanya dapat diubah menjadi Petugas bila tidak memiliki riwayat transaksi.
- Petugas dengan riwayat sebagai penanggung jawab pinjaman tidak dapat diubah menjadi Pengguna.
- Harus selalu ada minimal satu Superadmin; akun sendiri tidak dapat menurunkan rolenya.

8. Alur operasional ringkas

Peminjaman normal

Tahap	Pelaku	Hasil
1. Ajukan buku	Pengguna	Transaksi siap_diambil dan QR tersedia
2. Tunjukkan QR	Pengguna	QR diberikan kepada Petugas
3. Scan + jatuh tempo	Petugas	Status dipinjam; stok berkurang
4. Kembalikan	Pengguna/Petugas	Status dikembalikan; stok bertambah

Pengaduan dan denda

Tahap	Pelaku	Hasil
1. Kirim aduan + foto	Pengguna	Pengaduan baru
2. Periksa bukti	Petugas	Detail dan foto ditinjau
3. Tetapkan denda	Petugas	Tagihan menunggu dan notifikasi terkirim
4. Bayar	Pengguna	Metode dan waktu pembayaran tercatat
5. Bersihkan foto	Sistem	Foto dihapus 7 hari setelah pembayaran

Keterlambatan

Tahap	Pelaku	Hasil
1. Lewat jatuh tempo	Sistem	Status menjadi terlambat
2. Input denda	Petugas	Nominal dan jatuh tempo tagihan dibuat
3. Bayar	Pengguna	Status pembayaran dibayar
4. Validasi kembali	Petugas	Peminjaman selesai dan stok kembali

Rekomendasi SOP

- Petugas memeriksa identitas dan detail buku sebelum menyelesaikan scan QR.
- Untuk pinjaman terlambat, tetapkan denda sebelum menekan Validasi kembali.
- Jangan menghapus pengaduan/tagihan yang dibutuhkan sebagai bukti transaksi.

- Superadmin meninjau akun menunggu dan notifikasi setiap hari kerja.

9. Temuan audit teknis

Prioritas: Tinggi = berpotensi merusak data/keamanan; Sedang = alur utama atau hasil informasi keliru; Rendah = validasi, maintainability, atau pengalaman pengembang.

A-01 — Tinggi: Pengembalian dapat menambah stok dari status yang belum dipinjam

Bagian	Uraian
Bukti	Endpoint POST /api/loans/:id/return hanya menolak dikembalikan/dibatalkan. Status siap_diambil atau menunggu tetap dapat diproses, padahal stok belum pernah dikurangi.
Dampak	Stok dapat bertambah melebihi jumlah fisik melalui request API langsung.
Rekomendasi	Batasi status ke dipinjam/terlambat dan tambah uji transaksi stok.
Lokasi	server.js:39

A-02 — Tinggi: JWT memakai secret fallback yang mudah ditebak

Bagian	Uraian
Bukti	Jika JWT_SECRET tidak tersedia, server memakai 'ganti-rahasia-ini'. File contoh juga membawa nilai secret tetap.
Dampak	Token login dan QR dapat dipalsukan bila konfigurasi produksi lalai.
Rekomendasi	Hentikan startup saat secret kosong; gunakan secret acak per environment.
Lokasi	server.js:13; .env.example

A-03 — Sedang: Alur notifikasi peminjaman tidak sesuai status aktual

Bagian	Uraian
Bukti	Pinjaman baru langsung berstatus siap_diambil, tetapi notifikasi/alert staf hanya mengambil status menunggu.
Dampak	Petugas tidak menerima notifikasi peminjaman baru; endpoint review menjadi jalur lama yang tidak terpakai.
Rekomendasi	Gunakan siap_diambil untuk alert atau pulihkan tahap persetujuan secara konsisten.

Lokasi	server.js:31–32, 77, 85

A-04 — Sedang: Notifikasi pendaftaran dikirim kepada Petugas

Bagian	Uraian
Bukti	Notifikasi staf memasukkan target #/members untuk Petugas dan Superadmin, sementara route members hanya terbuka untuk Superadmin.
Dampak	Petugas yang mengklik notifikasi dialihkan kembali ke dashboard.
Rekomendasi	Filter notifikasi member hanya untuk Superadmin atau ubah target sesuai role.
Lokasi	server.js:77; public/app.js:24

A-05 — Sedang: Denda terlambat dapat dilewati sebelum pengembalian

Bagian	Uraian
Bukti	UI tetap menyediakan Validasi kembali untuk transaksi terlambat meskipun denda belum ditetapkan. Backend kemudian membuat fine_total otomatis tanpa fine_payments/jatuh tempo.
Dampak	Pengguna dapat melihat tagihan tanpa jatuh tempo dan proses Petugas menjadi tidak konsisten.
Rekomendasi	Wajibkan fine_payments sebelum return untuk status terlambat, atau gabungkan transaksi denda + return.
Lokasi	server.js:39, 80; public/app.js:104–105

9. Temuan audit teknis — lanjutan

A-06 — Sedang: Ringkasan metode pembayaran tidak lengkap

Bagian	Uraian
Bukti	Dashboard menghitung hanya QRIS dan VA BCA, sedangkan pembayaran menerima GoPay, DANA, dan OVO.
Dampak	Persentase dan total transaksi pada dashboard salah saat e-wallet digunakan.
Rekomendasi	Bangun chart dinamis dari seluruh hasil /api/admin/payment-summary.
Lokasi	public/app.js:42–43, 93; server.js:81

A-07 — Sedang: Menghapus pengaduan dapat meninggalkan pembayaran yatim

Bagian	Uraian
Bukti	fine_payments menyimpan source_id tanpa foreign key ke complaints. Endpoint hapus pengaduan tidak menghapus/menolak pembayaran terkait.
Dampak	Tagihan dapat hilang dari sisi Pengguna tetapi tetap muncul secara generik di sisi admin.
Rekomendasi	Blokir penghapusan jika ada pembayaran atau gunakan FK/soft delete dan transaksi atomik.
Lokasi	server.js:73, 80, 82; database/schema.sql:14

A-08 — Sedang: Tanggal memakai UTC, bukan zona aplikasi

Bagian	Uraian
Bukti	Validasi beberapa tanggal menggunakan toISOString().slice(0,10), yang menghasilkan tanggal UTC.
Dampak	Antara pukul 00.00–06.59 WIB, tanggal minimum/default dapat tertinggal satu hari.
Rekomendasi	Gunakan tanggal lokal Asia/Jakarta di server atau validasi tanggal melalui MySQL/CURDATE().
Lokasi	server.js:31, 37–39, 52; public/app.js:105

A-09 — Rendah: Masa berlaku QR dapat diperpanjang tanpa batas

Bagian	Uraian
Bukti	Token QR dua hari dibuat ulang setiap kali endpoint detail dipanggil, bukan dikunci sejak transaksi dibuat.
Dampak	Label “berlaku dua hari” tidak benar-benar membatasi umur pengambilan.
Rekomendasi	Simpan pickup_expires_at pada loan dan verifikasi terhadap waktu tersebut.
Lokasi	server.js:33

A-10 — Rendah: Belum ada test suite otomatis

Bagian	Uraian
Bukti	npm run check hanya menjalankan pemeriksaan sintaks. Tidak ada unit/integration test untuk role, transaksi, stok, atau denda.
Dampak	Regresi alur bisnis mudah lolos meskipun check berstatus sukses.
Rekomendasi	Tambah test API dengan database uji terisolasi dan kasus konkurensi.
Lokasi	package.json

10. Checklist verifikasi setelah perbaikan

Skenario uji	Hasil yang diharapkan
Return transaksi siap_diambil via API	Ditolak; stok tidak berubah.
Scan QR valid	Status dipinjam; stok berkurang tepat satu.
Scan QR kedua kali	Ditolak; stok tidak berubah.
Return dipinjam	Status dikembalikan; stok bertambah tepat satu.
Return terlambat tanpa denda	Ditolak atau sistem meminta denda terlebih dahulu.
Notifikasi pendaftaran sebagai Petugas	Tidak tampil atau tidak mengarah ke halaman terlarang.
Pembayaran GoPay/DANA/OVO	Dashboard memasukkan transaksi dan persentase dengan benar.
Hapus pengaduan bertagihan	Ditolak atau seluruh data terkait ditangani atomik.
Tanggal pukul 00.30 WIB	Default dan minimum sesuai tanggal lokal WIB.
QR lebih dari dua hari	Ditolak berdasarkan waktu kedaluwarsa transaksi.

Perintah pemeriksaan yang tersedia

- npm run check — memeriksa sintaks server.js dan public/app.js.
- npm ls --depth=0 — memeriksa dependensi terpasang/missing.
- Uji integrasi belum tersedia pada repository saat audit.

Batas audit

Audit ini merupakan review statis source code dan pemeriksaan tool lokal. Aplikasi tidak dijalankan terhadap database produksi, tidak dilakukan penetration test, dan tidak dilakukan simulasi beban. Temuan dapat bertambah setelah tersedia lingkungan uji end-to-end.

11. Troubleshooting

Masalah	Pemeriksaan dan solusi
Database tidak tersambung	Pastikan MySQL aktif, schema telah diimpor, serta DB_HOST, DB_PORT, DB_NAME, DB_USER, dan DB_PASSWORD benar.
Login ditolak	Periksa email/kata sandi dan pastikan akun Pengguna berstatus aktif.
Kamera tidak terbuka	Gunakan localhost atau HTTPS, izinkan kamera, tutup aplikasi lain yang memakai kamera, atau gunakan input QR manual.
QR ditolak	Pastikan status masih siap_diambil, token belum kedaluwarsa, dan QR belum pernah dipindai.
Upload cover gagal	Gunakan JPG/PNG/WebP maksimal 2 MB.
Upload bukti gagal	Maksimal lima gambar; 1,2 MB per gambar dan 5 MB total setelah kompresi.
Pengingat tidak muncul	Pastikan server terus aktif dan tagihan memiliki due_date serta status menunggu.
Sesi tidak dapat dipakai	Login ulang. Token berlaku tujuh hari dan aplikasi akan membersihkan sesi ketika server mengembalikan 401.

Sebelum deployment produksi

- Perbaiki seluruh temuan Tinggi dan Sedang.
- Ganti akun/kata sandi demo dan pakai JWT_SECRET acak.
- Aktifkan HTTPS dan rate limiting pada login/register.
- Gunakan akun MySQL dengan hak minimum dan jadwal backup.
- Integrasikan payment gateway jika pembayaran harus diverifikasi nyata.
- Pindahkan gambar ke object storage bila volume meningkat.
- Gunakan scheduler eksternal untuk pengingat dan cleanup yang tetap berjalan saat server restart.

12. Referensi teknis

Berkas	Fungsi
server.js	Express API, autentikasi, transaksi database, QR, notifikasi, dan scheduler.
public/app.js	Routing hash, tampilan SPA, modal, QR scanner, pembayaran, dan interaksi pengguna.
public/app.css	Tata letak dan styling aplikasi aktif.
database/schema.sql	Skema database awal dan data demo.
database/migrations/ 013_complaint_attachments.sql	Migrasi tabel lampiran pengaduan.
README.md	Petunjuk singkat instalasi.
DOKUMENTASI.md	Dokumentasi Markdown yang sudah ada di repository.

Endpoint utama

Kelompok	Endpoint
Autentikasi	/api/auth/login, /api/auth/register
Katalog	/api/categories, /api/books, /api/books/:id
Peminjaman	/api/loans, /api/loans/:id/pickup-qr, /api/loans/pickup/preview, /api/loans/pickup/scan
Pengembalian	/api/loans/:id/return, /api/loans/:id/fine
Pengaduan	/api/complaints, /api/complaints/:id/attachments
Denda	/api/member/fines, /api/admin/fine-payments
Notifikasi	/api/notifications, /api/admin/notifications
Akun	/api/admin/accounts, /api/admin/members

Penutup

Gunakan dokumen ini sebagai panduan operasional sekaligus backlog perbaikan. Setelah temuan prioritas diperbaiki, jalankan seluruh checklist verifikasi dan perbarui tanggal audit.